

Network Security — Lab Project

Université Libre de Bruxelles

STRIDE Threat Analysis

Milestone 1 — Initial Setup

March 2026

Teaching Assistant: Navid Ladner (navid.ladner@ulb.be)

Fernandez Ojeda Franklin (000541971)

Lecky-Thompson William (000613648)

Otto Aleksandra (000569128)

Rafaat Moheeb Eskandar Abanoub (000567614)

Introduction

Modern enterprise networks are exposed to a wide range of security threats, including external attacks, insider misuse, and protocol vulnerabilities. To address these risks, security engineering relies on threat modelling, a process used to identify, classify, and prioritise potential attacks before they occur.

In this project, we consider a simplified enterprise network composed of an Internet zone, an office network, and a server network hosting web services. At this stage, the infrastructure is not protected by any VPN or firewall, making it particularly exposed to various threats.

To analyse these risks, we use the STRIDE methodology, a framework that categorises threats into six types: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege.

1 Network Topology

The initial topology consists of three distinct network segments, connected in a chain through routers configured with RIPv2:

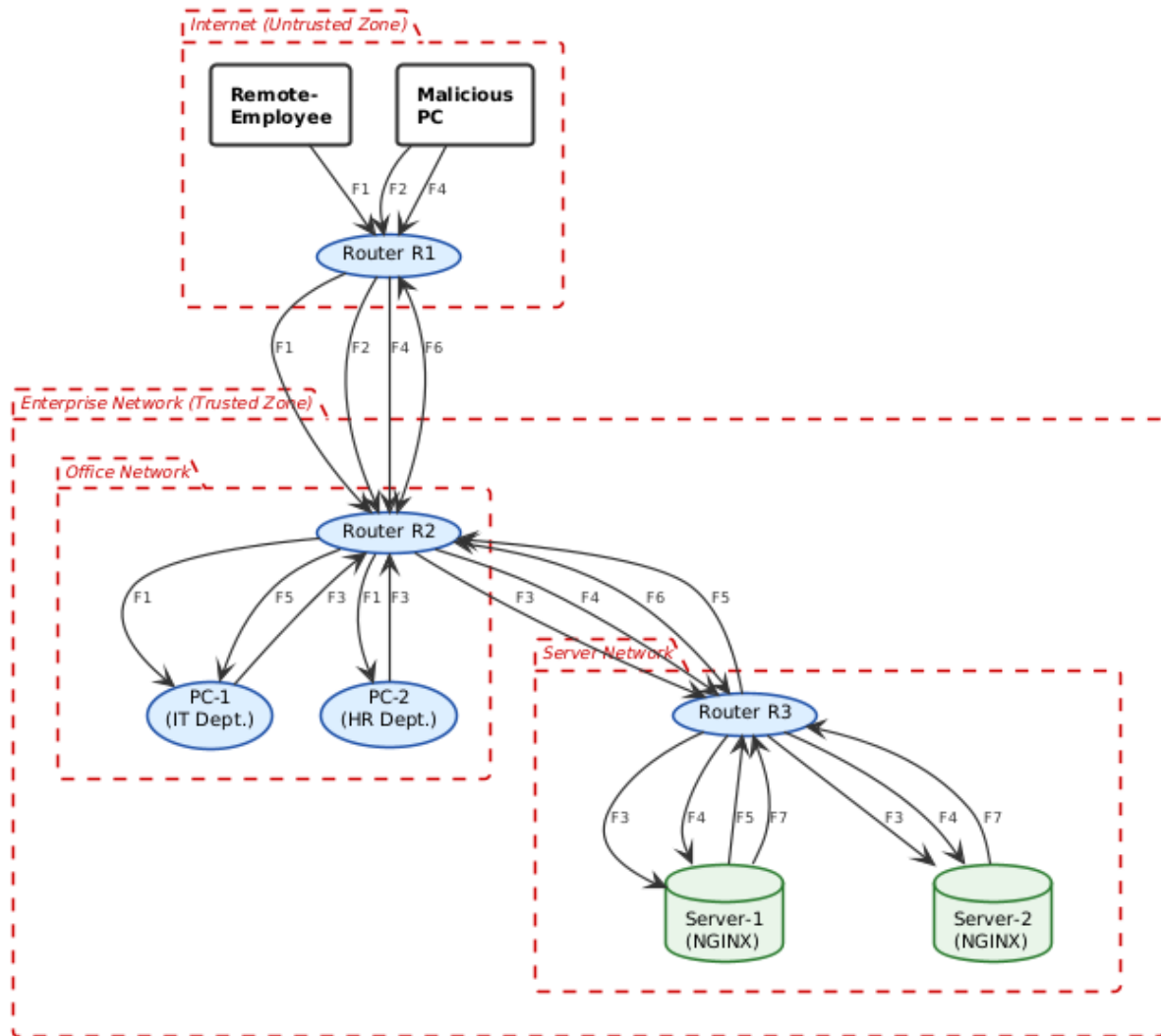
- External zone (Internet): Remote-Employee, Malicious PC, Router R1
- Office network: PC-1 (IT Dept.), PC-2 (HR Dept.), Router R2
- Server network: Server-1 and Server-2 (NGINX), Router R3

2 Identified Data Flows

The table below lists the seven data flows identified in the initial topology, along with the applicable STRIDE threat categories for each.

Flow	Description	STRIDE threats
F1	Remote-Employee → R1 → R2 → PC-1/PC-2	S, I, T, E
F2	Malicious PC → R1 → R2 → PC-1/PC-2	S, E, D, I, T
F3	PC-1/PC-2 → R2 → R3 → Servers	I, T, R
F4	Malicious PC → R1 → R2 → R3 → Servers	E, D, T, I
F5	Server → R3 → R2 → PC-1/PC-2	E, T, D
F6	RIPv2: R1 ↔ R2 ↔ R3	S, T, D
F7	HTTP responses from NGINX servers	I, R, T

STRIDE — Data Flow Diagram
Milestone 1 : Initial Setup (sans VPN / Firewall)



3 Selected Attacks

From the STRIDE analysis of the network flows, five representative attacks were selected based on their feasibility and potential impact.

3.1 A1 : Unauthorised access to servers (Elevation of Privilege)

For this attack, the attacker exploits the absence of filtering mechanisms to gain unauthorised access to internal servers. The attack uses flow F4, which allows a Malicious PC to reach Server-1 and Server-2 through the path $R1 \rightarrow R2 \rightarrow R3$. Since no firewall or access control is in place, this communication is not restricted. An attacker could therefore exploit a vulnerability in the NGINX service to compromise one of the servers. The risk score for this attack is Likelihood 4 and Impact 5, resulting in a score of **20 (Critical)**.

To mitigate this attack, a firewall should be deployed between the office network and the

server network. Only authorised traffic, specifically from PC-1 (IT Department), should be allowed to reach the servers. In addition, access control lists (ACLs) should be configured on R3 to enforce strict filtering policies.

3.2 A2 : IP Spoofing of the Remote-Employee (Spoofing)

For this attack, the attacker impersonates a legitimate remote employee by forging their IP address. The attack relies on flows F1 and F2, which allow communication between the external network and the office network without authentication. In the absence of a VPN or identity verification mechanism, the network cannot distinguish between a legitimate user and a malicious actor. The risk score is Likelihood 4 and Impact 4, giving a total of **16 (High)**.

To mitigate this attack, a VPN with certificate-based authentication should be implemented. This ensures that only legitimate users possessing valid certificates can establish a secure and trusted connection to the internal network.

3.3 A3 : Passive Traffic Interception / Sniffing (Information Disclosure)

For this attack, the attacker passively captures network traffic to extract sensitive information. The attack exploits flows F1 and F3, which carry unencrypted communications between the external zone and the office network, and between the office network and the servers. In the absence of any VPN or transport-layer encryption, all traffic traverses the network in plaintext. An attacker positioned anywhere along the path — including the Malicious PC on the same external segment as the Remote Employee — can use a packet analyser such as Wireshark to silently read credentials, session tokens, HTTP requests and responses, or any other sensitive data exchanged across these flows. Unlike active attacks, sniffing leaves no trace on the target systems and is therefore particularly difficult to detect. The risk score is Likelihood 4 and Impact 4, resulting in **16 (High)**.

To mitigate this attack, a site-to-site VPN with certificate-based authentication should be deployed to encrypt all traffic between the Remote Employee and the office network (flow F1). For internal flows between the office network and the servers (flow F3), the firewall deployed in Milestone 1 reduces the attack surface by restricting access to authorised hosts only, limiting the potential for sniffing on that segment.

3.4 A4 : SYN/HTTP Flood against NGINX (Denial of Service)

For this attack, the attacker aims to disrupt service availability by overloading the web servers. The attack targets flows F4 and F7, which expose the NGINX servers to external traffic. Without any rate limiting or protection mechanisms, an attacker can launch SYN or HTTP flooding attacks to exhaust server resources and deny access to legitimate users. The risk score is Likelihood 4 and Impact 3, resulting in **12 (Elevated)**.

To mitigate this attack, rate limiting should be configured on the NGINX servers using mechanisms such as `limit_req_zone`. SYN cookies should also be enabled at the operating system level to protect against SYN floods. Furthermore, access restrictions can be enforced through ACLs on R3.

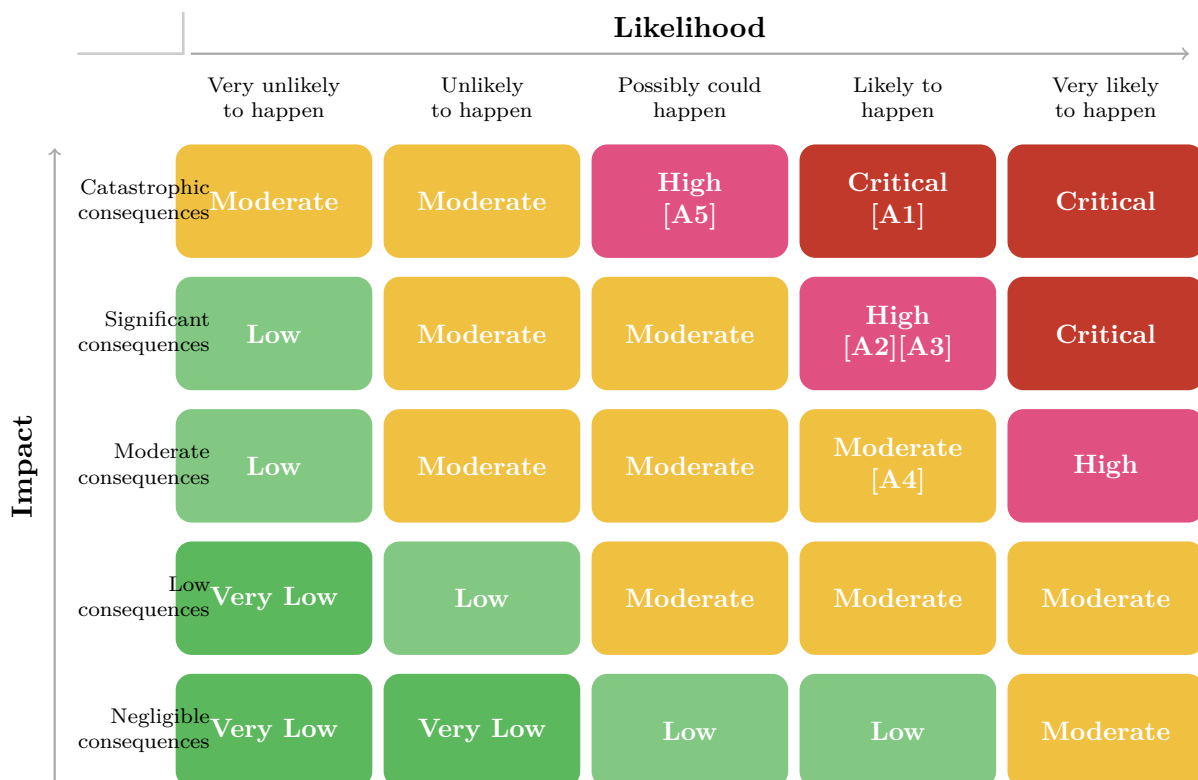
3.5 A5 : Lateral Movement from a Compromised Server (Elevation of Privilege)

For this attack, the attacker leverages a previously compromised server to move laterally within the network. The attack uses flow F5, which allows communication from the server network to the office network. Once a server is compromised, nothing prevents it from initiating connections toward internal workstations, potentially leading to further compromise and data exfiltration. The risk score is Likelihood 3 and Impact 5, resulting in **15 (High)**.

To mitigate this attack, strict network segmentation must be enforced. Firewall rules should explicitly block any traffic initiated from the server network toward the office network. This ensures adherence to the principle of least privilege and limits the potential impact of a compromise.

4 Risk Heatmap

The heatmap below places each of the five attacks on a 5×5 Likelihood $\times$ Impact grid. The colour of each cell indicates the risk level.



The table below summarises the position of each attack on the grid:

Attack	Threat type	Likelihood	Impact	Score
A1	Elevation of Privilege	4	5	20 — Critical
A2	Spoofing	4	4	16 — High
A3	Information Disclosure	4	4	16 — High
A4	Denial of Service	4	3	12 — Elevated
A5	Elevation of Privilege	3	5	15 — High

A1 (score 20) is the most critical attack: it is both easy to carry out and potentially devastating, as it gives an attacker direct control over a server. **A2** and **A3** (scores 16, High) are both easy to execute from outside the network and directly target the confidentiality of the enterprise: A2 by impersonating a legitimate user, A3 by passively reading all unencrypted traffic. Both are directly mitigated by the VPN. **A5** (score 15, High) requires a precondition — having already compromised a server — which lowers its likelihood. **A4** (score 12, Elevated) is easy to execute but has a limited impact since the servers do not hold critical data in this initial setup.

5 Summary

The table below maps each identified attack to the security component that addresses it in Milestone 1.

Attack	Main threat	Mitigation	Score
A1	Unauthorised server access (E)	Firewall: block external traffic towards R3	20
A2	IP Spoofing (S)	Site-to-site VPN with certificates	16
A3	Passive sniffing / plaintext traffic (I)	VPN encryption + Firewall restrictions	16
A4	SYN/HTTP flood NGINX (D)	ACLs on R3 + NGINX rate limiting	12
A5	Server pivot to office (E)	Firewall: block server-initiated traffic	15

Attacks A1 and A2 are the most critical and directly motivate the two security components required in Milestone 1: the **Firewall** and the **VPN**. A3 is equally serious and is mitigated by the VPN for external flows and by the firewall for internal flows. A5, while serious, will be addressed as a direct effect of the firewall deployment. A4 will be more fully mitigated in Milestone 2 with the Web Application Firewall.